

Sumário do Resultado: Plano de Testes de Segurança para o Sistema de Reserva de Salas

Autor: Cleydson Soares de Freitas

Componente Curricular: DevSecOps e Desenvolvimento Seguro (Secure SDLC)

Data: 14 de Maio de 2026

1. Introdução e Escopo do S-SDLC

Este relatório apresenta o sumário do resultado obtido no **Passo 5 (Plano de Testes de Segurança)** para o software de reserva de salas. Com base nas etapas prévias de modelagem de ameaças (Passo 1), definição de controles (Passo 2) e design de arquitetura segura com segregação de privilégios (Passos 3 e 4), foi estabelecido um ecossistema de testes robusto. O objetivo é validar a eficácia dos mecanismos de autenticação, autorização e resiliência do sistema contra tentativas de bypass e exploração de falhas lógicas antes da promoção do código para o ambiente produtivo.

2. Metodologia de Testes de Segurança Adotada

O plano de testes adota uma abordagem híbrida de auditoria, combinando segurança automatizada na esteira e testes manuais orientados à perspectiva de ataque (foco em Purple Team):

- **SAST (Static Application Security Testing):** Análise estática de código-fonte na esteira CI/CD para identificar vulnerabilidades antes da compilação (ex: credenciais hardcoded, bibliotecas desatualizadas).
- **DAST (Dynamic Application Security Testing):** Análise dinâmica do binário em execução para avaliar o comportamento do software contra injeções e falhas de transporte.
- **Testes de Lógica de Negócio (Abuse Cases):** Validação manual de fluxos para garantir que as regras restritivas do sistema não possam ser manipuladas por parâmetros maliciosos.

3. Matriz Executiva do Plano de Testes de Segurança (Passo 5)

Abaixo encontra-se a decomposição dos cenários críticos de testes projetados especificamente para validar as superfícies de ataque do sistema de reserva de salas:

ID do Teste	Categoria / Tipo	Cenário de Ataque / Caso de Abuso	Resultado Esperado de Segurança
TST-SEC-01	Autenticação (DAST/Manual)	Bypass de Autenticação: Tentativa de acessar a listagem de salas ou forçar uma reserva enviando requisições sem um token ativo de sessão.	O sistema deve interceptar a chamada de forma mandatória, negar o acesso e retornar código HTTP 401 (Unauthorized).
TST-SEC-02	Autorização / RBAC (Lógica)	Elevação de Privilégio Horizontal/Vertical: Usuário com perfil "Comum" tenta forçar o cancelamento de uma reserva enviando o ID da reserva via requisição direta.	O backend deve rejeitar a operação ao validar que a flag isAdmin é falsa, gerando um log de alerta de segurança.
TST-SEC-03	Integridade / Regra de Negócio	Race Condition / Conflito Induzido: Submissão simultânea e concorrente (via scripts de estresse) de duas requisições de reserva para a mesma sala e horário.	O mecanismo de concorrência ou banco de dados deve bloquear a segunda requisição, mantendo apenas uma reserva íntegra.
TST-SEC-04	Análise de Código (SAST)	Vulnerabilidades de Implementação: Varredura do repositório Java utilizando ferramentas open source (como Semgrep ou OWASP Dependency-Check).	O pipeline deve travar (Build Fail) caso sejam detectadas falhas graves (High/Critical) ou dependências vulneráveis.
TST-SEC-05	Tratamento de Erros (DAST)	Vazamento de Informação (Information Leakage): Inserção de caracteres inválidos nos campos de horário para tentar forçar estouro de pilha (<i>stack trace</i>).	A aplicação deve tratar a exceção de forma genérica, ocultando detalhes da infraestrutura ou linhas do código Java.

4. Estratégia de Mitigação e Próximos Passos

Os testes descritos nesta matriz serão executados de forma contínua e automatizada. Qualquer falha identificada nos cenários acima gerará um impedimento imediato de implantação (*Deployment Block*). Os resultados das varreduras SAST/DAST e as tentativas de bypass serão documentados e compartilhados entre as frentes de desenvolvimento e segurança para correção na origem, fechando o ciclo de melhoria contínua do Secure SDLC.